IA Aplicada com LLMs

Aula 12 — Governar a ação

Objetivos

Ao final deste deck, espera-se que o aluno seja capaz de:

- **definir** governança de IA agêntica e **distinguir** risco de saída de risco de ação;
- **explicar** o agente como problema de agência e por que a responsabilidade permanece com a organização que o implanta (KOLT, 2025; SHAVIT et al., 2023);
- **situar** os controles nas funções do NIST AI RMF e **distinguir** esse marco da ISO/IEC 42001;
- **especificar** a autoridade de um agente — escopo, ações proibidas, identidade, privilégio mínimo, limites de gasto, limiar de aprovação — e **reconhecer** credencial herdada, confiança entre agentes e deriva de autoridade;
- **localizar** onde cada limite é aplicado e **justificar** por que ação consequente exige limite determinístico ou aprovação humana, e não detecção de conteúdo;
- **projetar** a supervisão humana: *in-the-loop* ou *on-the-loop*, limiar de escalonamento, interrupção e matriz de responsabilidade.

Parte 1

Governança e risco de ação

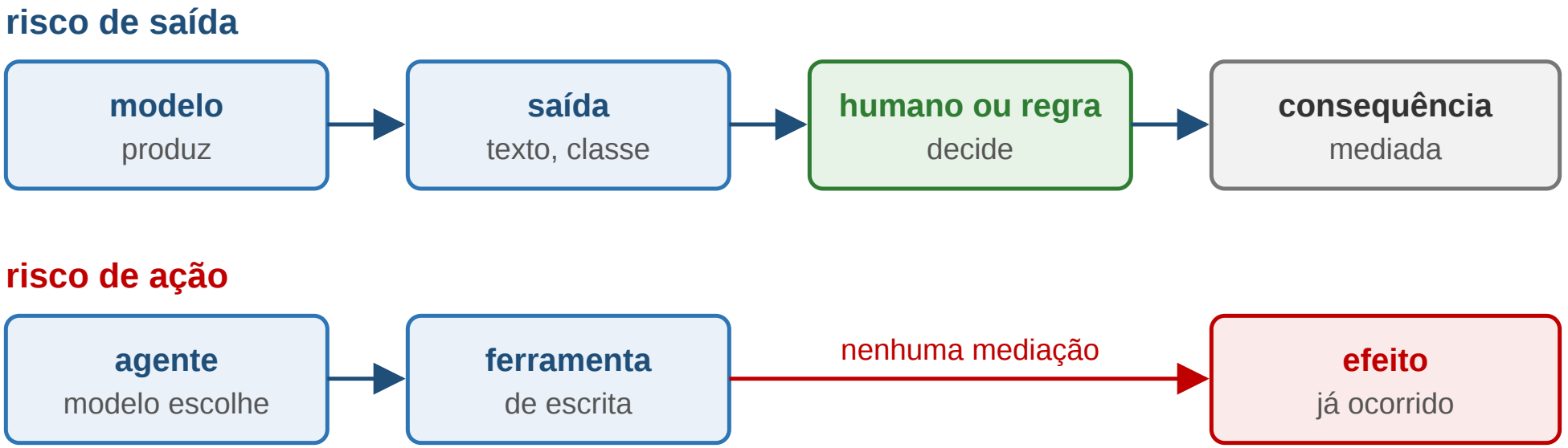
Governança de IA agêntica governa uma concessão de autoridade

Governança de IA agêntica: conjunto de políticas, controles técnicos e atribuições de responsabilidade com que uma organização gere a **autoridade delegada** a sistemas que planejam e executam ações em seu nome — o que podem acessar e fazer, sob que supervisão, e quem responde pelo que fazem.

Componente	Pergunta a responder antes de o agente operar
limite	o que o agente está autorizado a fazer, com que dados e até que valor
supervisão	quem acompanha a operação, quando intervém e como a interrompe
responsabilização	quem responde por cada classe de falha, e com que registro se demonstra o que aconteceu

- Um agente, no sentido construído na aula de arquitetura de agentes, é um laço em que o modelo escolhe a próxima ferramenta; cada ferramenta de escrita — registrar parecer, enviar mensagem, pagar — é uma capacidade de alterar o mundo concedida pela organização.
- Este deck trata de **o que o agente está autorizado a fazer, e quem aplica esse limite**. Demonstrar o que foi decidido, com base em quê, é o assunto da nota sobre provar a decisão; o texto legal, o da nota sobre legislação.

Risco de saída × risco de ação



- **Risco de saída**: o sistema produz resultado incorreto, enviesado ou inexplicável, que alguém consome e sobre o qual decide. **Risco de ação**: o sistema **executa** uma operação indevida — altera registro, move dinheiro, envia comunicação, concede acesso.
- Num agente, a mediação desaparece no ponto em que o modelo escolhe uma ferramenta de escrita: o erro de raciocínio deixa de ser saída a revisar e passa a ser efeito ocorrido.

Quando todos poderiam ter evitado, a atribuição precisa vir antes do dano

O caso de Shavit et al. (2023): um assistente encarregado de comprar ingredientes para um *cheesecake* japonês compra uma passagem aérea cara para o Japão, e o usuário só percebe quando o reembolso já não é possível. Poderiam ter evitado o dano o desenvolvedor do modelo (confiabilidade), quem implantou (aprovação antes de compras), o usuário (não delegar compra a sistema pouco confiável) e a companhia aérea (consentimento humano). Cada um pode atribuir a culpa aos demais; a governança existe para que a atribuição esteja feita antes.

	Risco de saída	**Risco de ação**
objeto	o resultado produzido	a operação executada
mediação até a consequência	decisão humana ou regra de negócio	nenhuma, se a ferramenta de escrita está disponível ao modelo
reversão	descartar a saída	desfazer a operação, quando possível
controle típico	avaliação do modelo, revisão da saída	limite de autoridade, aprovação, interrupção

O risco de ação **soma-se** ao de saída: o parecer do auditor de despesas pode estar errado (saída) e, com a ferramenta que efetiva o reembolso, o erro vira pagamento indevido (ação).

Parte 2

Agência e moldura

O agente de IA é um problema de agência

Problema de agência (*principal-agent problem*): um **principal** delega a um **agente** autoridade para agir em seu nome, e o agente dispõe de informação e margem de decisão que o principal não controla. Kolt (2025) identifica três problemas:

Problema	No agente de IA	Nome já visto no curso
assimetria de informação	o agente observa ambiente, conteúdo recuperado e resultado das ferramentas; o principal vê o que ele registra	o motivo do *trace*, na aula de arquitetura de agentes
autoridade discricionária	a tarefa não especifica cada passo; o agente escolhe caminhos não enumerados — a razão de usar agente e não *workflow*	o espectro de autonomia
lealdade	o agente persegue outro objetivo: especificação incompleta, deriva numa trajetória longa, instrução injetada	deriva e sequestro de objetivo, na aula de segurança

- Incentivo, monitoramento e sanção, com que se governa um agente humano, podem não bastar: opacidade, velocidade e escala; Kolt propõe infraestrutura guiada por inclusividade, visibilidade e responsabilização (*liability*).
- **A responsabilidade não se delega junto com a autoridade.** Para todo dano direto causado por um sistema agêntico deve haver ao menos uma entidade humana — pessoa, empresa, entidade jurídica — responsável por ele (SHAVIT et al., 2023).

NIST AI RMF: quatro funções para situar cada controle

NIST AI Risk Management Framework (AI RMF 1.0, NIST AI 100-1): marco voluntário de gestão de riscos de IA, de janeiro de 2023 (NIST, 2023).

Função	Finalidade	No agente
Govern	cultura, políticas, papéis e responsabilização; **transversal**, permeia as outras três	quem aprova a autoridade do agente; quem pode desligá-lo
Map	contexto: finalidade, ambiente, partes afetadas, impactos	que despesas o agente analisa; quem é afetado por um parecer
Measure	analisar e acompanhar riscos com testes, métricas e avaliações	a suíte da aula de *evals*, a suíte hostil da aula de segurança, o painel da aula de observabilidade
Manage	priorizar e responder: mitigar, transferir, aceitar, recuperar-se	limites, aprovação humana, interrupção, registro de risco aceito

- *Govern* não é etapa anterior: é a condição que dá às outras responsável, critério e registro.
- **NIST AI 600-1** (2024), o perfil de IA generativa: doze riscos próprios ou agravados — confabulação, privacidade, segurança da informação, configuração humano-IA (viés de automação, dependência excessiva), integridade da cadeia de valor — com ações sugeridas por função (NIST, 2024).
- Valor para esta aula: vocabulário comum. Função sem controle é lacuna visível.

A ISO/IEC 42001 certifica a organização, não o agente

ISO/IEC 42001:2023: norma de **sistema de gestão** (*management system*) — requisitos para estabelecer, implementar, manter e melhorar continuamente um sistema de gestão de IA, na família estrutural da ISO/IEC 27001, com ciclo planejar-executar-verificar-agir e anexo de controles de referência (ISO; IEC, 2023).

	NIST AI RMF	ISO/IEC 42001
natureza	marco voluntário de gestão de risco	norma de requisitos para sistema de gestão
objeto	riscos de sistemas de IA ao longo do ciclo de vida	o sistema de gestão de IA da organização
certificação	não há	certificável por terceira parte
uso nesta aula	vocabulário para situar cada controle	referência de que governança é processo contínuo

Limite. O certificado atesta que a organização tem processo para governar seus sistemas de IA — definição de política, avaliação de risco, operação, melhoria. Não atesta que um dado agente esteja corretamente limitado.

Parte 3

Autoridade delegada

Escopo e ações proibidas: o conjunto autorizado se garante em código

Especificação de autoridade: documento que declara, antes da implantação, o que o agente faz, o que nunca faz e com que dados.

- **escopo** — finalidade, ferramentas e, para cada uma, se é de leitura ou de escrita e se a escrita é reversível;
- **ações proibidas** — operações nunca executadas, ainda que tecnicamente possíveis;
- **dados** — fontes lidas e categorias de dado pessoal que podem entrar no contexto.

A proibição **não é redundante** com o escopo: o escopo diz quais ferramentas existem; a proibição restringe o uso de uma existente — o auditor tem `registrar_parecer`, e "não aprovar acima de um valor" restringe um argumento dela.

Com $\mathcal{A}$ o conjunto de ações que as ferramentas permitem, $E \subseteq \mathcal{A}$ o escopo e $P \subseteq \mathcal{A}$ as proibidas:

$$\mathcal{A}_{\text{aut}} = E \setminus P$$

O controle garante **em código** que toda ação executada pertença a $\mathcal{A}_{\text{aut}}$. Escrita no prompt, a proibição é instrução concorrente com qualquer outra que chegue ao contexto — e prompt não é mecanismo de segurança, como mostrou a aula de segurança.

Identidade própria e privilégio mínimo

O agente opera com **identidade própria**: credencial de serviço emitida para ele, distinta da do usuário que o aciona e da do desenvolvedor. Sobre ela vale o **privilégio mínimo**: exatamente as permissões necessárias às ferramentas do escopo.

Problema resolvido	Sem identidade própria
atribuição	o *log* atribui à pessoa as ações do agente, e não há como distinguir o que um fez do que o outro fez
alcance	a credencial ampla de uma pessoa concede ao agente tudo o que ela pode; um desvio — erro de raciocínio, instrução injetada — opera com esse alcance

- **ASI03 — Identity and Privilege Abuse** (OWASP, 2025): sem identidade própria e governada, o agente opera numa lacuna de atribuição que impede aplicar de fato o privilégio mínimo.
- O privilégio mínimo vale **por ferramenta**: a leitura de despesas não escreve; o registro de parecer escreve numa única tabela; nenhuma das duas acessa a folha de pagamento.
- A aula de segurança classificou essa medida como a defesa mais barata disponível; como requisito de governança, permissão não justificada pelo escopo é **autoridade concedida sem decisão**.

Três vias que ampliam a autoridade sem que ninguém a conceda

Via	Mecanismo	Correção
credencial herdada	o agente recebe o contexto de acesso integral de quem o aciona: o gerente de alto privilégio delega uma consulta e repassa todas as permissões; inclui credencial guardada em memória e reutilizada noutra sessão, por outro usuário	o delegado recebe credencial restrita à subtarefa — a **interseção**, não a união
confiança entre agentes	um agente aceita pedido de outro agente interno como legítimo por vir de dentro — o **representante confuso** (*confused deputy*): uma mensagem forjada leva o agente de triagem de correio a pedir ao agente financeiro uma transferência, e ele paga	mensagem de outro agente é entrada não confiável; o pedido é verificado contra a autoridade do usuário original
verificação antecipada (TOCTOU)	a autorização é checada no início da compra; horas depois o limite do usuário cai, e o *workflow* conclui com o *token* antigo	verificar a autorização **no momento da ação** (*time-of-check to time-of-use*)

As duas primeiras estão entre os exemplos de ASI03; a comunicação insegura entre agentes é **ASI07 — Insecure Inter-Agent Communication** (OWASP, 2025). A fronteira, no curso, é o *handoff* e o *Agent Card* do A2A, da aula de sistemas multiagente.

Regra comum: a autoridade de um agente não pode ser maior do que a concedida a ele, independentemente de quem o acionou.

Deriva de autoridade: autoridade efetiva cresce, declarada fica

Deriva de autoridade: crescimento da autoridade efetiva sem decisão explícita de ampliá-la, por acréscimos que parecem configuração:

- **ferramenta nova** para um caso específico; **servidor MCP novo**, que expõe várias ferramentas de uma vez, inclusive de escrita;
- **atualização de servidor MCP aprovado** cuja descrição ou ferramentas mudam depois da aprovação — o *rug pull* da aula de MCP;
- **permissão ampliada** na credencial para resolver um erro de acesso; **prompt novo** que muda o comportamento sem mudar ferramenta.

Com $\mathcal{A}_{\text{dec}}$ a autoridade declarada e $\mathcal{A}_{\text{ef}}(t)$ a efetiva — o que as ferramentas conectadas, com as credenciais concedidas, permitem em t —, a especificação está cumprida enquanto

$$\mathcal{A}_{\text{ef}}(t) \subseteq \mathcal{A}_{\text{dec}}$$

A deriva é $\mathcal{A}_{\text{ef}}(t) \setminus \mathcal{A}_{\text{dec}}$, monotônica enquanto ninguém a mede. **Controle**: toda mudança de ferramenta, servidor ou permissão passa pela revisão que aprovou a especificação; periodicamente, a autoridade efetiva é recalculada a partir do que está conectado e comparada com a declarada — o desvio de configuração da infraestrutura como código, da aula de empacotamento, aplicado a permissões.

Visibilidade é pré-requisito de todo controle

Visibilidade sobre agentes de IA: conhecimento sobre onde, por que, como e por quem os agentes são usados (CHAN et al., 2024). Três medidas, de intrusividade e informatividade crescentes:

Medida	Definição	No agente do curso
identificador do agente	indica a quem interage que se trata de um agente e o associa a quem o implantou	credencial de serviço própria; identificador em cada chamada e registro
monitoramento em tempo real	supervisão da atividade enquanto ocorre, com possibilidade de sinalizar ou bloquear	painel e alerta da aula de observabilidade; o ponto de aplicação de política
registro de atividade	guarda de entradas e saídas para análise posterior	o *trace* persistido em todos os caminhos de término

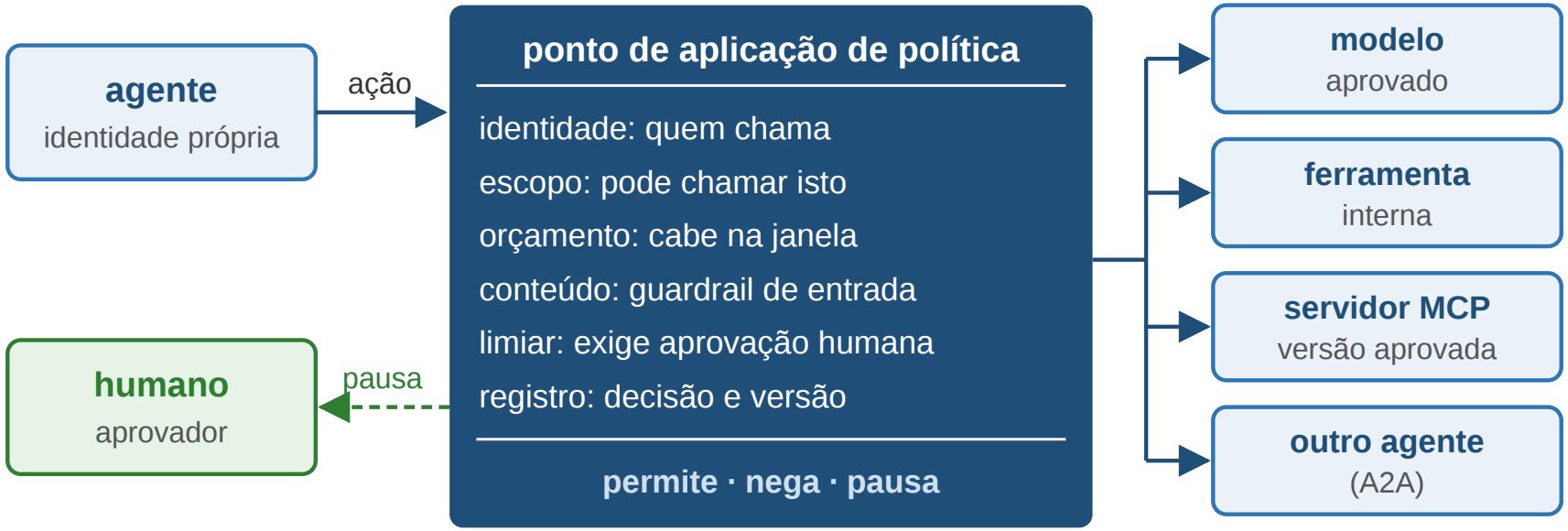
- Os autores discutem também os custos de privacidade e de concentração de poder dessas medidas.
- Conclusão operacional: **agente sem identificador, sem monitoramento e sem registro não é governável** — não há como saber se cumpre a especificação nem reconstruir o que fez. O registro como evidência é o assunto da nota sobre provar a decisão.

Parte 4

Controle em tempo de execução

Política declarada só é controle com ponto de aplicação

Política declarada: regra escrita — especificação, documento, prompt. **Política aplicada**: regra executada por um componente que intercepta a operação e a permite, nega ou suspende — o **ponto de aplicação de política** (*policy enforcement point*). Regra sem ponto de aplicação é intenção, não controle.



- Quatro operações atravessam fronteira: chamada de **modelo** (qual, com que dados, em que orçamento), de **ferramenta** (qual, com que argumentos e credencial), a **servidor MCP** (aprovado, em que versão, que ferramentas) e a **outro agente** (a quem, com que autoridade, o que se aceita de volta).
- O retorno de cada destino volta pelo mesmo ponto e é **entrada não confiável** para o agente.

A decisão é função determinística, e o modelo não participa dela

```
def decidir(acao, agente, estado):
    if acao.ferramenta not in agente.escopo:
        return "negar", "fora do escopo"
    if agente.proibe(acao):
        return "negar", "ação proibida"
    if estado.gasto_janela + acao.custo_estimado > agente.limite_janela:
        return "negar", "limite de gasto da janela"
    if acao.impacto() >= agente.limiar_aprovacao:
        return "pausar", "aguarda aprovação humana"
    return "permitir", None
```

- **Inescapável por prompt**: os argumentos vêm da chamada que o modelo propôs, mas a regra é código, e nenhum texto no contexto a altera — a confirmação da nota sobre defesa por arquitetura, da aula de segurança.
- **Devolve o motivo**: negar por escopo e negar por gasto exigem correções opostas, como no orçamento da aula de arquitetura de agentes. A **pausa** é resultado próprio: o término "aguardando humano".
- **Três lugares**, que não se excluem: o **código do agente** (`Orcamento`, confirmação), a **plataforma** (a permissão da credencial no banco nega a escrita qualquer que seja a tentativa — a última linha, porque vale quando o código falha) e um **plano de controle comum** a vários agentes.

O *gateway* é um desenho para escala, não a definição de governança

LLM *gateway*: serviço interposto entre as aplicações e os provedores de modelo; a aplicação aponta para ele, e ele encaminha a chamada. Concentrando também ferramentas, MCP e A2A, torna-se **plano de controle comum**:

- políticas, segredos (as chaves dos provedores ficam nele, não em cada aplicação) e telemetria num só lugar;
- regra alterada vale para todos os agentes sem reimplantação;
- a governança define as regras, o *gateway* as aplica em cada requisição e registra a decisão (JANICKI, 2026, texto de fornecedor, leitura complementar).

Limites.

- Não é condição necessária: resolve um problema de escala — muitos agentes, muitas equipes, regras iguais para todos. Um único agente pode ter os mesmos controles no próprio código e nas permissões da plataforma.
- Fica no **caminho crítico** de toda chamada: sua falha é a falha de todos os agentes que dependem dele, e o comportamento nessa falha é decisão a declarar (*fail-open* × *fail-closed*).

Custo é limite com responsável, por execução e por janela

O `Orcamento` da aula de arquitetura de agentes limita **uma execução** ($T_{\max}$ tokens, $R_{\max}$ reais). Com n execuções numa janela, o gasto só é limitado por $n \cdot R_{\max}$, e n não está sob controle do agente: fila reprocessada, cliente que reenvia em laço, agente sequestrado. O **limite por janela** fecha a lacuna — para cada chave k e janela $w \in \{\text{dia}, \text{semana}, \text{mês}\}$:

$$G_w(k) = \sum_{e \,\in\, \text{execuções de } k \text{ em } w} c(e) \;\le\; L_w(k), \qquad \text{alerta quando } G_w(k) \ge \alpha\, L_w(k),\ \alpha < 1$$

- **janelas sobrepostas** — diária, semanal e mensal: limite só mensal permite consumir o mês num dia;
- **uma chave por carga de trabalho**: a chave é a unidade de atribuição e de corte; chave compartilhada impede dizer qual agente gastou e desligar só ele;
- **limites por equipe ou usuário**, quando o agente atende a vários;
- **roteamento só entre modelos aprovados** — política de dados, região de processamento e avaliação;
- **contexto como alavanca**: o que reduz o contexto reduz também a exposição de dado ao provedor.

Aumento súbito de gasto ou de negações é sinal de mau funcionamento ou comprometimento; a aula de segurança leu o teto de gasto como **contenção de dano**.

Guardrails reduzem, não eliminam

Guardrail: verificador de conteúdo aplicado à entrada ou à saída de uma chamada de modelo, que bloqueia, mascara ou sinaliza.

Família	Alcance	Limite
detecção por padrão	expressões regulares e validadores: CPF, cartão, chave de API, *e-mail*	precisa no que tem formato fixo, cega ao que não tem
detecção por modelo	classificador: nome de pessoa, condição de saúde em prosa, *jailbreak*, injeção	falso negativo estrutural na injeção: basta à instrução maliciosa parecer instrução

Com taxa de falso negativo p e N tentativas de ação indevida numa janela, atravessam em média pN — positivo para todo $p > 0$, crescente com a exposição. Um limite determinístico ("nenhuma aprovação acima de R$ 1.000 sem humano") não tem falso negativo para a regra que expressa.

Regra de projeto: ação consequente depende de **limite determinístico ou aprovação humana**, não de detecção de conteúdo. O *guardrail* segue útil para reduzir o volume que chega ao limite e mascarar dado pessoal antes do provedor (JANICKI, 2026).

Fail-open × *fail-closed* se escolhe pelo risco da operação

Todo controle no caminho pode falhar — *gateway* indisponível, *guardrail* em *timeout*, consulta ao limite sem resposta. O comportamento na falha é decisão declarada:

	Fail-open	***Fail-closed***
controle não responde	a operação prossegue sem ele	a operação é negada
preserva	disponibilidade	controle
com controle de disponibilidade d	sem controle numa fração $1 - d$ do tempo	disponibilidade no máximo d
adequado a	leitura de baixo risco, com registro da falha	escrita consequente: aguarda o controle ou vai a humano

- *Fail-open* em operação consequente equivale a declarar que o limite vale só enquanto o controle está no ar.
- **Modelo de reserva** (*fallback*): admissível só se cumprir **as mesmas políticas** do principal — retenção, uso para treino, região, avaliação na suíte de *evals* (JANICKI, 2026). *Fallback* para provedor não aprovado é *fail-open* da política de dados.

Parte 5

Supervisão humana e desligamento

Human-in-the-loop × human-on-the-loop

	Human-in-the-loop	***Human-on-the-loop***
momento	antes da ação: uma pessoa **aprova**	durante e depois: uma pessoa **monitora**
execução	suspensa até a decisão — o término "aguardando humano"	prossegue sem aprovação prévia
poder de quem supervisiona	aprovar ou negar	suspender, reverter, corrigir

- A aprovação limita falhas graves — certas decisões, como iniciar sozinho uma transação grande e irreversível, são importantes demais para delegar (SHAVIT et al., 2023).
- **Limite**: quem aprova precisa de contexto para entender o que aprova, e quem aprova muitas decisões decide cada uma depressa. **Aprovação em excesso degenera em carimbo.**
- O AI Act exige que quem supervisiona um sistema de alto risco permaneça consciente do **viés de automação**, a tendência de confiar automaticamente na saída (UNIÃO EUROPEIA, 2024, art. 14, n. 4, b; nota sobre legislação, §4.3).
- A escolha não é global: o mesmo agente usa *in-the-loop* no alto impacto e *on-the-loop* no resto; o critério é o limiar de escalonamento.

O limiar de escalonamento usa propriedades verificáveis da ação

Limiar de escalonamento: regra que determina quais ações suspendem a execução e seguem para aprovação humana, e para quem. Formulado sobre propriedades **verificáveis** da ação — nunca sobre a confiança declarada pelo modelo, que é texto gerado e manipulável.

Propriedade	Critério
valor	montante envolvido comparado com um limite numérico
irreversibilidade	se a operação pode ser desfeita, e a que custo: parecer registrado e não efetivado é reversível; pagamento executado não é
dado sensível	dado pessoal sensível (saúde, por exemplo) ou efeito sobre direitos de uma pessoa

- O limiar define **o destino** da pausa: o papel que aprova, o prazo e o que ocorre no vencimento — numa ação consequente, **não executar**, e não executar por omissão.
- **Calibragem**: confirmação em excesso suprime a autonomia que justificava o agente; de menos, deixa passar a ação que justificava o controle. O limiar é parâmetro revisado com dados — fração de execuções que pausam, tempo de espera, fração de aprovações alteradas pelo humano.

Interromper: um procedimento nunca executado é hipótese

Interruptibilidade: capacidade de suspender um agente em operação, de forma controlada, a qualquer momento. Dois níveis — interromper uma categoria de ação (revogar o acesso a credenciais financeiras) ou encerrar o agente. Requisitos (SHAVIT et al., 2023): desligamento **gracioso**, com contingência para interrupção no meio de uma sequência; o agente **não pode impedir nem adulterar** a tentativa; a interrupção **alcança os subagentes**. O AI Act exige, em alto risco, intervir ou interromper o sistema por botão de parada ou procedimento semelhante que o leve a estado seguro (UNIÃO EUROPEIA, 2024, art. 14, n. 4, e).

Pergunta	Exemplo de resposta
quem pode interromper	o operador de plantão e o responsável pelo produto
como	desativar a chave do agente no ponto de aplicação; revogar a credencial de serviço na plataforma
em que estado fica	execuções em curso terminam como interrompidas, sem escrita parcial; *trace* persistido
como se testa	exercício periódico de desligamento em homologação, com tempo medido até a última ação

O teste é o que costuma faltar: a chave desativada pode não ser a que o agente usa, a credencial revogada pode estar em *cache*, uma execução em segundo plano pode continuar. Os dois mecanismos se complementam: o ponto de aplicação é rápido e seletivo; a revogação na plataforma vale mesmo se ele for contornado.

A matriz de responsabilidade tem um único papel por falha

Forma operacional de "a responsabilidade não se delega ao agente": cada classe de falha recebe, antes do incidente, o papel que responde. Papéis: **produto** (finalidade, escopo, limiar), **desenvolvimento** (ferramentas, limites, registro), **operação** (monitora, responde a alertas, interrompe), **risco** (aprova a especificação, aceita risco residual, revisa a deriva).

Falha	Responde	Participa
ação fora do escopo executada	desenvolvimento (o limite não foi aplicado)	risco (a especificação foi aprovada assim)
escopo inadequado à finalidade	produto	risco
limite de gasto excedido sem alerta	operação	desenvolvimento
agente não interrompido a tempo	operação	produto (quem decide interromper)
permissão acumulada sem revisão	risco	desenvolvimento
aprovação humana dada sem exame	produto (desenho do limiar e da tela)	operação

Ambiguidade na coluna "responde" reproduz o caso de Shavit et al. (2023): cada participante atribui a falha aos demais.

Parte 6

A autoridade do auditor de despesas

O auditor especificado: escopo, dados e credencial

Ferramentas das aulas de arquitetura de agentes e de MCP; valores ilustrativos, a fixar pelo responsável pelo produto.

Item	Especificação	Onde é aplicado
finalidade	analisar despesas e registrar parecer (aprovar, recusar, encaminhar), citando o trecho do regulamento	especificação; prompt de sistema
ferramentas	as três de leitura; `registrar_parecer`, escrita reversível: o parecer não efetiva pagamento	lista de ferramentas; ponto de aplicação
servidores MCP	só o da política, em versão fixada; servidor ou versão nova passa por revisão	ponto de aplicação; revisão de deriva
dados	a despesa, seus comprovantes e o regulamento; nunca folha de pagamento nem despesas de outros	permissões da credencial na plataforma
ações proibidas	alterar política ou regulamento; efetivar reembolso ou pagamento; aprovar acima de R$ 1.000 sem humano; parecer sem trecho citado	ausência da ferramenta (alterar, pagar); regra no ponto de aplicação (valor, citação)
credencial	conta de serviço própria: lê despesas e regulamento, escreve só na tabela de pareceres; nunca a do funcionário nem a do desenvolvedor; segredo fora do repositório, com rotação	plataforma (banco, cofre de segredos)
delegação	não delega; se vier a delegar, credencial restrita à subtarefa	especificação; revisão de deriva

O auditor especificado: limites, supervisão e revisão

Item	Especificação	Onde é aplicado
limite por execução	60.000 tokens e R$ 0,50, 12 passos, 120 s	`Orcamento` no código do agente
limite por janela	chave exclusiva; R$ 120 por mês (cerca de 1,5 vez o custo mensal medido), R$ 10 por dia; alerta a 80% de cada limite	ponto de aplicação (*gateway* ou código)
modelos	só os da lista aprovada; reserva só com a mesma política de dados, região e resultado na suíte de *evals*	ponto de aplicação
limiar de aprovação humana	pausa para o analista financeiro: toda recusa, toda aprovação acima de R$ 1.000, toda despesa com dado de saúde; prazo de 2 dias úteis; vencido, o parecer não é registrado	ponto de aplicação; término "aguardando humano"
falha de controle	*fail-closed* para `registrar_parecer`; *fail-open* com registro para as leituras	ponto de aplicação
interrupção	o plantão desativa a chave e, se preciso, revoga a credencial; a retomada é decidida pelo produto; exercício de desligamento trimestral	ponto de aplicação; plataforma
revisão de autoridade	a cada ferramenta, servidor ou permissão nova, e a cada trimestre: efetiva comparada com declarada	processo (*Govern*), responsável: risco
visibilidade	identificador do agente em toda chamada e registro; painel e alerta de gasto e de negações; *trace* em todo término	observabilidade

Três decisões da especificação, e o que ela não cobre

- **Ausência de ferramenta** é o controle mais forte das ações proibidas: o auditor não efetiva reembolso porque não existe ferramenta para isso, e nenhuma instrução no contexto cria uma.
- **Toda recusa vai a humano**: é a decisão que afeta um funcionário de forma adversa e a mais provável de ser contestada. O tratamento da contestação e a revisão de decisão automatizada da LGPD (art. 20) estão nas notas sobre provar a decisão e sobre legislação.
- **O limite por janela vem da medição**: a nota sobre a conta, da aula de observabilidade, chega a cerca de R$ 78 por mês (1.900 execuções a R$ 0,041); a folga de cerca de 50% interrompe o anômalo sem interromper o crescimento normal. Limite fixado sem medição seria arbitrário nos dois sentidos.

O que falta. A especificação diz o que o agente **pode** fazer; não demonstra, sozinha, a um terceiro — o funcionário, um auditor, a autoridade de proteção de dados — o que ele **fez** numa execução específica. Essa é a outra metade da governança, objeto da nota sobre provar a decisão.